

Trust the Pipeline, Lose the Kingdom

DEF CON 34 Red Team Village — Shane Young — @x90sky

What you just did live

Force-merged a pull request you did not own, using AWS credentials your own PR-controlled pipeline step printed from a trusted workflow. No C2. No implant.

The live command path

- **Step 1 — Fork:** fork the Totally Not Vulnerable Repo.
- **Step 2 — Review the pipeline configs:** open `.github/workflows/ci.yml`.
- **Step 2.5 — Spot the vulnerable lines:** find `pull_request_target`, PR checkout, and bash `"$STUDENT_STEP"`.
- **Step 3 — Add submission JSON:** create `submissions/YOUR_HANDLE.json` with `{"handle":"YOUR_HANDLE","message":"your message"}`.
- **Step 3.5 — Add pipeline step:** create matching `ci/student-steps/YOUR_HANDLE.sh`.
- **Step 4 — Open PR:** target the room demo repo, not your fork.
- **Step 5 — Download STS artifact:** download `sts-credentials`, open `sts-creds.sh`, and paste the exports.
- **Step 6 — Verify AWS identity:** run `aws sts get-caller-identity`.
- **Step 7 — Read demo PAT:** read `demo/github-pat` into PAT.
- **Step 8 — Merge your PR:** call `curl -X PUT .../pulls/${PR_NUMBER}/merge` with PAT.
- **Step 9 — Refresh trophy wall:** wait for GitHub Pages if the wall lags.

The advanced chain we walk through with artifacts/code

Beyond the live path:

- Native cloud persistence can be built with services such as serverless functions and schedules.
- `sts:AssumeRole` trust chains can turn a scoped build role into a broader role.
- `GetSecretValue` on higher-value secrets is where cloud compromise can become enterprise compromise.

The public Terraform/code bundle is the take-home path for reproducing the full chain later in a dedicated, empty AWS account.

Real-world precedent

Technique	Incident	Year
Compromised CI with downstream blast radius	SolarWinds	2020
CI credential exfil via bash uploader	Codecov	2021
CI platform compromise with widespread impact	CircleCI	2023
Compromised GitHub Action, log-based exfil	tj-actions/changed-files	March 2025
Mass GitHub Actions secret exfil	GhostAction	September 2025
Turning Trivy and Checkmarx Actions into credential stealers	TeamPCP	March 2026

Detection signals deployable today

CloudTrail filters

- `GetSecretValue` from OIDC build session ID, targeting admin-class secret names
- `AssumeRoleWithWebIdentity` from unexpected source IPs against OIDC-trusted roles
- `CreateFunction` or `PutRule` where the principal is any build role

GitHub audit log / workflow telemetry

- PR merge events where the actor is a PAT caller and the PR has zero human reviews
- `pull_request_target` workflow invocations from first-time contributors

Config audit

- Any workflow using `pull_request_target` with `actions/checkout` on `github.event.pull_request.head.sha`
- OIDC-trusted IAM roles with permissions broader than a single build use case

Trust boundaries that need to exist

- Build infrastructure should not have access to admin-class secrets.
- OIDC-trusted roles should be scoped per-workflow, per-repo, per-branch — never shared, never broad.
- CI roles should not create durable cloud compute or schedules by default.
- The merge API is not a security boundary if your PAT has repo scope. Gate merges through branch protection + required reviews that cannot be self-approved, and treat every admin PAT as infrastructure.

Live training docs

Attendee landing page: <https://x90sky.sh/rtv>



Reproduce the full chain at home

Public bundle:

<https://github.com/x90skysn3k/rtv-cicd-attack-chain>

Use it with a dedicated, empty AWS account you control to review the live lab, safe demo repository, advanced chain artifacts/code, and public detection examples. Only attendee-safe material is published in the bundle.

Contact

- GitHub: [x90skysn3k](https://github.com/x90skysn3k)
- Twitter/X: [@x90sky](https://twitter.com/x90sky)